

YAHOO DATA BREACH (2013-2014)

Presented by:

Thanigaivel S(192565006)

Dept: Cybersecurity

Subject: Ethical hacking(ITA-1411)

Guided by:

Dr.Ezhil grace



INTRODUCTION

- The Yahoo Data Breach occurred between 2013 and 2014 but was publicly disclosed in 2016.
- It is considered one of the largest data breaches in history.
- Cyber attackers stole sensitive information from all 3 billion Yahoo user accounts.
- Stolen data included names, email addresses, phone numbers, dates of birth, hashed passwords, and security questions.
- The breach significantly damaged Yahoo's reputation and business value.



BACKGROUND OF THE CASE

Target

- Yahoo Inc., one of the world's largest email and web service providers.

Other Parties Involved

- Yahoo users worldwide
- U.S. Federal Bureau of Investigation (FBI)
- U.S. Department of Justice (DOJ)
- Verizon Communications (acquired Yahoo in 2017)
- Cybersecurity investigators
- The attackers gained unauthorized access to Yahoo's internal systems and databases, stealing massive amounts of user information over an extended period.



INCIDENT

- The breaches occurred in 2013 and 2014 and were disclosed in 2016.

Attack Flow

- **Phishing / Stolen Credentials → Unauthorized Server Access → Database Compromise → User Data Stolen → Data Sold or Misused**
- Attackers gained access to Yahoo's internal network.
- User account databases were compromised.
- Personal information of billions of users was stolen.
- Forged authentication cookies allowed attackers to access user accounts without passwords.
- The breach remained undetected for several years.



CYBERCRIME / LEGAL ISSUES

The case involved several cybercrimes:

- Unauthorized access to computer systems
- Large-scale data theft
- Identity theft
- Privacy violations
- Computer-related fraud
- Unauthorized use of authentication cookies
- International cybercrime
- The incident demonstrated the severe consequences of weak security monitoring and delayed breach disclosure.



RELEVANT IT ACT SECTIONS

The following provisions of the Information Technology Act, 2000 are relevant:

Section	Relevance
Section 43	Unauthorized access and damage to computer systems
Section 66	Computer-related offences committed dishonestly or fraudulently
Section 66C	Identity theft and misuse of electronic credentials
Section 66D	Cheating by personation using computer resources
Section 72	Breach of confidentiality and privacy



INVESTIGATION AND EVIDENCE

The investigation involved:

- Analysis of Yahoo server logs
- Digital forensic examination
- Review of compromised user databases
- Investigation of forged authentication cookies
- Cooperation between Yahoo, the FBI, and cybersecurity experts
- Identification of attack methods and affected accounts
- Investigators concluded that the breach affected all 3 billion Yahoo user accounts, making it the largest known data breach at the time.



COURT DECISION / LEGAL OUTCOME

- In **2017**, Yahoo agreed to pay **\$35 million** to settle charges with the U.S. Securities and Exchange Commission (SEC) for failing to disclose the breach promptly.
- Several individuals associated with the hacking operation were indicted by the U.S. Department of Justice.
- Verizon reduced its acquisition price of Yahoo by **\$350 million** due to the breach.
- Yahoo strengthened its cybersecurity practices after the incident.



IMPACT OF THE CASE

The Yahoo Data Breach was significant because it:

- Affected 3 billion user accounts worldwide.
- Exposed sensitive personal information.
- Damaged Yahoo's reputation and customer trust.
- Reduced Yahoo's acquisition value.
- Increased awareness of timely breach disclosure.
- Encouraged stronger cybersecurity measures and better password security across the industry



LESSONS LEARNED & CONCLUSION

Lessons Learned

- Use strong password hashing and encryption.
- Enable Multi-Factor Authentication (MFA).
- Monitor networks continuously for suspicious activities.
- Perform regular security audits and vulnerability assessments.
- Promptly disclose security breaches.
- Educate users about phishing attacks and password safety.

Conclusion

- The Yahoo Data Breach demonstrated how inadequate security controls and delayed incident disclosure can lead to one of the largest cybersecurity incidents in history. It highlighted the importance of robust cybersecurity practices, continuous monitoring, rapid incident response, and compliance with data protection laws to safeguard user information.



HACKERONE ACTIVITY

1. Organization Name

- Rocket.Chat

2. Vulnerability Title

- Stored XSS in Rocket.Chat HTML File Export — Unauthenticated Entry via LiveChat

3. Vulnerability Category

- Cross-site Scripting (XSS) - Stored

4. Brief Description

- A security flaw was found in the application's HTML file export feature. The system failed to properly clean or escape user-provided data before embedding it into the exported file. This allowed an unauthenticated attacker to inject malicious JavaScript code into the export data.

5. What Was the Security Impact?

- When a user opened the exported HTML file, the injected malicious code would automatically execute in their browser. This could lead to severe outcomes like unauthorized data exfiltration (stealing sensitive data) and credential phishing. The vulnerability was officially assigned a Medium severity rating.

6. Disclosure Process Followed

- The bug hunter (username: olidayw) identified the issue and reported it directly to the Rocket.Chat security team through their HackerOne bounty program. After the technical team validated and patched the flaw, the report was mutually and transparently disclosed to the public.

7. Was Responsible Disclosure Followed?

- Yes. The researcher privately reported the security flaw to the vendor first, giving Rocket.Chat the time required to build, test, and deploy a fix before any details were

8. Could Full Disclosure Have Been Dangerous?

- Yes. Had the details been fully disclosed immediately (zero-day disclosure), malicious actors could have easily exploited the unauthenticated entry via LiveChat to compromise Rocket.Chat instances globally, stealing user data before organizations had a chance to patch their software.

9. Lessons Learned

- Never Trust User Input: All user-supplied text must be strictly sanitized and HTML-escaped before it is rendered or bundled into file exports.
- Review Edge-Case Features: Secondary features like file exporters or reporting tools often bypass standard web-application filters and require dedicated security oversight.
- Authentication Boundaries: Features exposed to unauthenticated interfaces (like LiveChat) must be treated with the highest level of scrutiny.

10. Conclusion

- The incident highlights the immense value of bug bounty programs. Through the collaborative efforts of an independent researcher and the Rocket.Chat security team, a potentially damaging entry point was quietly secured, keeping user communication data safe without exposing the platform to active wild exploitation.

CVE ACTIVITY

1. Introduction to CVE

- The Common Vulnerabilities and Exposures (CVE) program is a global, standardized dictionary of publicly known cybersecurity flaws. Managed by the MITRE Corporation, it assigns unique tracking IDs (like CVE-2026-24141) so security tools, vendors, and researchers can easily share information and fix bugs.

2. Vulnerability Description

- CVE-2026-24141 is a high-severity flaw in the NVIDIA Model Optimizer (Windows & Linux) within its ONNX model quantization feature. It is classified under CWE-502: Deserialization of Untrusted Data. The application fails to sanitize model files before loading them, allowing an attacker to craft a malicious input file that triggers unauthorized commands.

3. Disclosure Timeline

- Discovery & Reporting: Identified by researchers and privately reported directly to NVIDIA.
- Patch Development: NVIDIA created security fixes to eliminate the unsafe data processing logic.
- Public Publication: March 24, 2026 (Officially published to the global CVE directory).
- Remediation: Released alongside NVIDIA Security Advisory a_id/5798.

4. Analysis

- The core issue is that the application blindly trusts data structures inside machine learning files.
- CVSS 3.1 Score: 7.8 (High)
- Attack Mechanism: An attacker tricks a user into opening a poisoned ONNX model file.

5. Responsible Disclosure Evaluation

- Coordinated Disclosure was successfully followed. The researchers kept the bug private until NVIDIA could fix it. If full disclosure had happened immediately, attackers could have uploaded infected AI models to public repositories (like Hugging Face), compromising data science teams and cloud servers worldwide before a patch existed.

6. Conclusion

- CVE-2026-24141 highlights that the modern AI/ML supply chain is highly vulnerable to traditional security flaws like unsafe deserialization. NVIDIA addressed this by patching all versions prior to 0.41.0, proving that private vendor collaboration is essential to keeping developers safe.